

Progetto Cyber Blog: Audit di Sicurezza e Hardening Infrastrutturale

Analisi delle vulnerabilità, esecuzione di exploit e implementazione di mitigazioni architetturali.

Presentazione per il Gruppo Classe e
Valutatori Accademici.

Panorama delle Sfide di Sicurezza e Architettura dell'Audit

1. Denial of Service (DoS)

Assenza di Rate Limiter e saturazione risorse.

2. Privilege Escalation & CSRF

Operazioni critiche esposte in GET.

3. Violazione Accountability

Assenza di log applicativi e di Non-repudiation.

4. SSRF (Server-Side Request Forgery)

Manomissione input e proxying illecito.

5. Stored XSS

Mancata sanitizzazione dell'input.

6. Mass Assignment

Configurazione permissiva dei Modelli Dati.



Sfida 1: Assenza di Rate Limiter e Vulnerabilità DoS

Analisi Tecnica

La rotta pubblica `/articles/search` esponeva il database a interrogazioni massive senza restrizioni. Ogni chiamata forzava un'operazione di query computazionalmente dispendiosa, portando rapidamente alla saturazione delle risorse del server.

Vettore di Attacco

```
for i in {1..200}; do
  curl -s -o /dev/null -w "%{http_code}\n"
  "http://cyber.blog:8000/articles/search?query=cyber"
& done
```

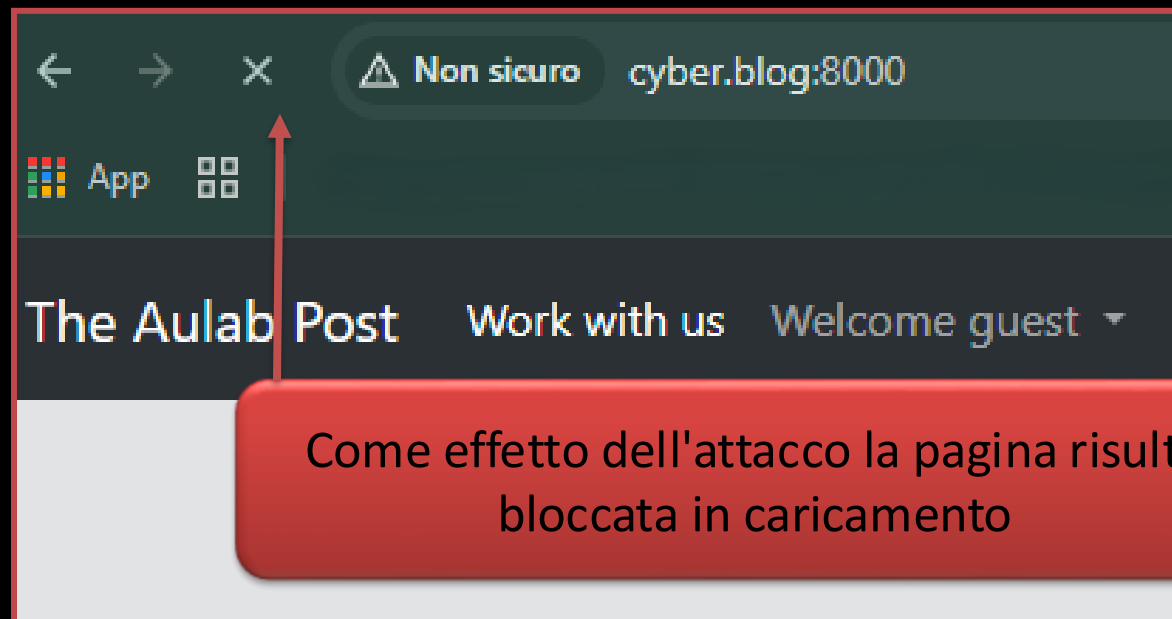
```
2026-05-06 00:12:19 /articles/search ..... ~ 501.03ms
2026-05-06 00:12:19 /articles/search ..... ~ 514.92ms
2026-05-06 00:12:19 /articles/search ..... ~ 515.91ms
2026-05-06 00:12:20 /articles/search ..... ~ 514.44ms
2026-05-06 00:12:20 /articles/search ..... ~ 514.35ms
2026-05-06 00:12:20 /articles/search ..... ~ 501.07ms
2026-05-06 00:12:21 /articles/search ..... ~ 501.50ms
```

MINGW64:/c/users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/...

BELLANOVA@DESKTOP-5E8FAS9 MINGW64 /c/users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/XXX-AttackTools/dos (main)

```
$ for i in {1..200}; do curl -s -o /dev/null "http://cyber.blog:8000/articles/search?query=cyber" & done
```

```
[201] 9047
[202] 9048
[203] 9049
[204] 9050
[205] 9051
[206] 9052
[207] 9053
[208] 9054
[209] 9055
[210] 9056
[211] 9057
[212] 9058
[213] 9059
[214] 9060
[215] 9061
[216] 9062
[217] 9063
[218] 9064
[219] 9065
[220] 9066
[221] 9067
[222] 9068
[223] 9069
[224] 9070
[225] 9071
[226] 9072
[227] 9073
[228] 9074
[229] 9075
[230] 9076
```



Soluzione Architeturale

Utilizzo delle funzionalità native di Laravel 11 per limitare il throughput basandosi sull'indirizzo IP del client, preservando le risorse del database.

AppServiceProvider.php

```
// CHALLENGE 1: Definizione del Rate Limiter per la ricerca
RateLimiter::for('search_limiter', function (Request $request) {
    return Limit::perMinute(10)->by($request->ip());
});
```

```
routes/web.php

//CHALLENGE 1 Limitazione richieste
Route::get('/articles/search', [ArticleController::class, 'articleSearch'])
    ->name('articles.search')
    ->middleware('throttle:search_limiter');
```

[illegible]

Il server intercetta l'abuso scartando le richieste eccedenti con stato HTTP 429. Sito operativo.

Il server intercetta l'abuso scartando le richieste eccedenti con stato HTTP 429. Sito operativo.

Sfida 2: Operazioni Critiche in GET (Bypass CSRF)

Le assegnazioni dei ruoli amministrativi in GET bypassano le difese CSRF, esponendo a Vertical Escalation of Privileges.

L'esca: Admin visita pagina esterna



Esecuzione: JS forza chiamata GET con cookie



Impatto: Escalation dei privilegi



Privilege escalation completa

Welcome back, admin: Steve Lorren (Admin)

Mitigazione 2: Transizione a PATCH e Token Validation

Soluzione Architettuale

Conversione rigorosa delle rotte al metodo HTTP PATCH, riattivando intrinsecamente le difese middleware CSRF di Laravel tramite token crittografici.

```
components/requests-table.blade.php
<form action="{{route('admin.setAdmin', $user)}}" method="POST">
  @csrf
  @method('PATCH')
  <button type="submit" class="btn btn-secondary">Enable {{$role}}</button>
</form>
```

```
web.php
Route::patch('/admin/{user}/set-admin', [AdminController::class, 'setAdmin'])->name('admin.setAdmin');
Route::patch('/admin/{user}/set-revisor', [AdminController::class, 'setRevisor'])->name('admin.setRevisor');
Route::patch('/admin/{user}/set-writer', [AdminController::class, 'setWriter'])->name('admin.setWriter');
```

Verifica Forense

Symfony\Component\HttpFoundation\Exception\MethodNotAllowedHttpException

The GET method is not supported for route admin/2/set-admin. Supported methods: PATCH.

Expand vendor frames

31 vendor frames

C:\Users\jonat\wa-hack178\CYBERSECURITY_specializzazione\progFinCyber\progetto-finale-cyber-giovani-bellanova\public\index.php:17
require_once

1 vendor frame

```
C:\Users\jonat\wa-hack178\CYBERSECURITY_specializzazione\progFinCyber\progetto-finale-cyber-giovani-bellanova\public\index.php:17
1  <?php
2
3  use Illuminate\Http\Request;
4
5  define('LARAVEL_START', microtime(true));
6
7  // Determine if the application is in maintenance mode...
8  if (file_exists($maintenance = __DIR__.'/../storage/framework/maintenance.php')) {
9      require $maintenance;
10 }
11
12 // Register the Composer autoloader...
13 require __DIR__.'/../vendor/autoload.php';
14
15 // Bootstrap Laravel and handle the request...
16 (require_once __DIR__.'/../bootstrap/app.php')
17     ->handleRequest(Request::capture());
```



Attacco respinto: le richieste GET dirette generano ora un'eccezione. I token CSRF sono obbligatori.

Sfida 3: Violazione dei Principi di Accountability

Il sistema originale registrava unicamente eccezioni tecniche e stack trace, risultando **completamente muto** rispetto alle azioni di **business logic**.

Impatto Critico:

- Assenza di **Accountability**: Impossibilità di associare un'azione a un'identità.
- Violazione della **Non-repudiation**: Mancanza di prove digitali per impedire a un utente di negare un'operazione.

```
laravel.log X
storage > logs > laravel.log
1 [2026-04-07 18:25:01] production.ERROR: Database file at path
[C:\Users\jonat\wa-hack178\CYBERSECURITY_specializzazione\progFinCyber\progetto-finale-cyber-giovanni-bellanova\database\database.sqlite] does
not exist. Ensure this is an absolute path to the database. (Connection: sqlite, SQL: select exists (select 1 from sqlite_master where name =
'categories' and type = 'table') as "exists") {"exception": "[object] (Illuminate\\Database\\QueryException(code: 0): Database file at path
[C:\Users\jonat\wa-hack178\CYBERSECURITY_specializzazione\progFinCyber\progetto-finale-cyber-giovanni-bellanova\database\database.
sqlite] does not exist. Ensure this is an absolute path to the database. (Connection: sqlite, SQL: select exists (select 1 from sqlite_master
where name = 'categories' and type = 'table') as \"exists\") at C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/
progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/Illuminate/Database/Connection.php:825)
2 [stacktrace]
3 #0 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->runQueryCallback()
4 #1 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->run()
5 #2 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->select()
6 #3 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->selectOne()
7 #4 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->scalar()
8 #5 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Database/Connection.php:825: Illuminate/Database/Connection->scalar()
9 #6 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/app/Providers/
AppServiceProvider.php:11: Illuminate/Container/Container->make()
10 #7 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Container/Container.php:730: Illuminate/Container/Container->make()
11 #8 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Container/Util.php(43): Illuminate/Container/Container->make()
12 #9 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Container/Container.php(730): Illuminate/Container/Util::make()
13 #10 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Container/Container.php(730): Illuminate/Container/Container->make()
14 #11 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Container/Container.php(730): Illuminate/Container/Container->make()
15 #12 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Foundation/Application.php(1151): Illuminate/Container/Container->make()
16 #13 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Foundation/Application.php(1132): Illuminate/Foundation/Application->bootProvider()
17 #14 [internal function]: Illuminate/Foundation/Application->{closure:Illuminate/Foundation/Application->bootProvider()}()
18 #15 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/
Illuminate/Foundation/Application.php(1132): Illuminate/Foundation/Application->bootProvider()
```

LOG MUTO - NESSUNA TRACCIABILITÀ

Mitigazione 3: Auditing Diffuso e Tracciabilità Event-Driven

Soluzione Architeturale

Implementazione di **logging capillare** nei controller sensibili tramite **Log::info()** e mappatura dei cicli **Auth** (Login/Logout) tramite **Event Listener**.

```
1
2 Log::info("L'amministratore " . Auth::user()->name .
3 " (ID: " . Auth::user()->id . ") ha promosso
4 l'utente " . $user->name . " a ruolo ADMIN.");
5
6
```

```
[2026-05-19 12:28:14] local.INFO: L'amministratore Mario Bianchi (Super admin) (ID: 6) ha CREATO la categoria: abbigliamento
[2026-05-19 12:36:16] local.INFO: L'amministratore Steve Lorren (Admin) ha ELIMINATO il tag: trench
[2026-05-19 13:01:29] local.INFO: L'utente Mario Bianchi (Super admin) (ID: 6) ha CREATO l'articolo: 'Trench' (ID: 2)
[2026-05-19 13:02:12] local.INFO: L'amministratore Mario Bianchi (Super admin) ha ELIMINATO il tag: trench
[2026-05-19 14:41:50] local.INFO: LOGOUT: L'utente Mario Bianchi (Super admin) (ID: 6) è uscito dal sistema.
[2026-05-19 14:42:01] local.INFO: LOGIN: L'utente Antony Delgado (Revisor) (ID: 4) ha effettuato l'accesso.
[2026-05-19 14:43:05] local.INFO: Il revisore Antony Delgado (Revisor) (ID: 4) ha ACCETTATO l'articolo: 'Il trench'
[2026-05-19 14:43:13] local.INFO: Il revisore Antony Delgado (Revisor) (ID: 4) ha RIPORTATO IN REVISIONE l'articolo: 'Il trench'
[2026-05-19 14:43:26] local.INFO: LOGOUT: L'utente Antony Delgado (Revisor) (ID: 4) è uscito dal sistema.
[2026-05-19 14:43:51] local.INFO: LOGIN: L'utente Daria Richardson (Writer) (ID: 3) ha effettuato l'accesso.
[2026-05-19 14:44:38] local.DEBUG: From: CyberBlog <hello@example.com>
```

```
To: admin@theaulabpost.it
Subject: Nuova richiesta di lavoro ricevuta
MIME-Version: 1.0
Date: Tue, 19 May 2026 14:44:38 +0000
Message-ID: <72d4fe64113ba7c7b03ae5079c58793c@example.com>
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable
```

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Document</title>
</head>
<body>
  <h1>È arrivata una richiesta per il ruolo di admin</h1>
  <p>Ricevuta da writer@aulab.it</p>
  <h4>Messaggio:</h4>
  <p>&lt;p&gt;gregergegegre&lt;/p&gt;</p>
</body>
</html>
```

```
[2026-05-19 14:44:38] local.INFO: L'utente Daria Richardson (Writer) (ID: 3) ha inviato una richiesta per il ruolo: ADMIN
[2026-05-19 14:44:41] local.INFO: LOGOUT: L'utente Daria Richardson (Writer) (ID: 3) è uscito dal sistema.
[2026-05-19 14:44:54] local.INFO: LOGIN: L'utente Mario Bianchi (Super admin) (ID: 6) ha effettuato l'accesso.
[2026-05-19 14:45:02] local.INFO: L'amministratore Mario Bianchi (Super admin) (ID: 6) ha promosso l'utente Daria Richardson (Writer) (ID: 3) a ruolo ADMIN.
```

QUANDO
(Timestamp)

CHI
(Identità certa)

COSA
(Azione tracciata)

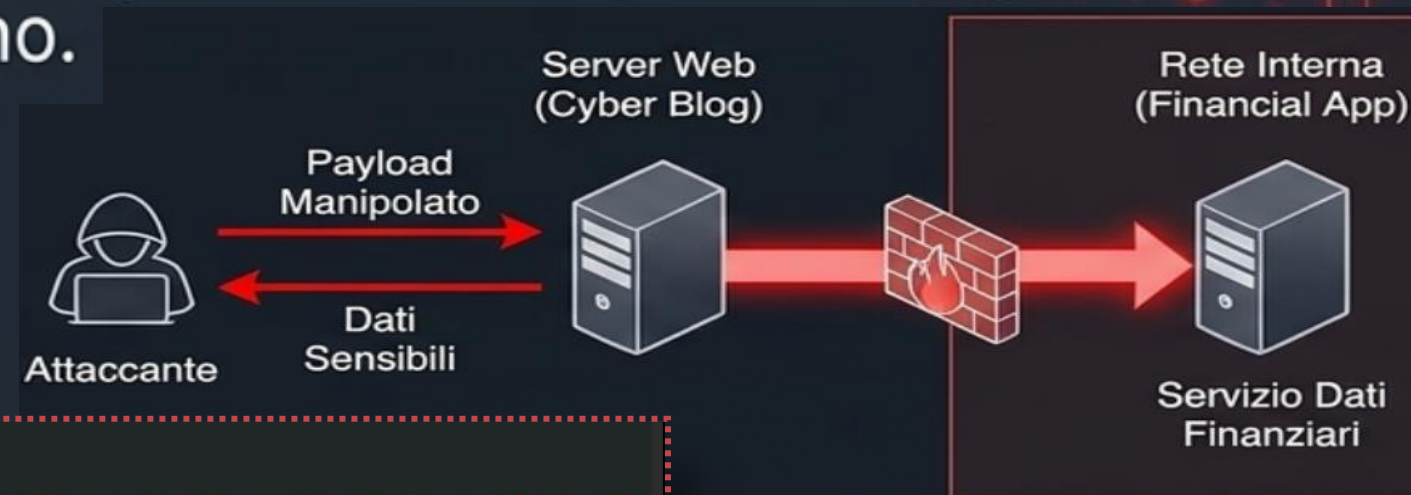


Sistema di audit conforme: tracciabilità completa, responsabilità chiara, prove forensi integre.

Sfida 4: Manomissione Input e SSRF (Server-Side Request Forgery)

Il componente Livewire **LatestNews.php** accettava URL client-side senza validazione, trasformando il server web in un proxy involontario per interrogare servizi finanziari interni inaccessibili dall'esterno.

L'attaccante riesce a visualizzare i dati bancari degli utenti in ispezione elemento



```
:[[{"user_id":1,"username":"john_doe","account_balance":1500.75,"transactions":[[{"transaction_id":"txn001","d
```

```
Headers Payload Preview Response Initiator Timing Cookies
{
  "components": [
    {
      "snapshot": "{ \"data\": { \"selectedApi\": \"http:\\\\\\\\\\\\internal.finance:8001\\\\\\\\user-data.php\", \"news\": { \"users\": [[ { \"user_id\":1, \"username\": \"john_doe\", \"account_balance\":1500.75, \"transactions\": [[ { \"transaction_id\": \"txn001\", \"d
      \"effects\": {
        \"returns\": [
          null
        ],
        \"html\": \"<div wire:id=\\\"H96bmYrrgqfLoR0xHDNx\\\">\n    <h3>Articles suggestions for you, get inspired!</h3>\n    <form wire:submit=\\\"fetchNews\\\">\n      <label for=\\\"apiSelect\\\">Breaking news around the world</label>\n    <div class=\\\"
      }
    ],
    \"assets\": []
  }
}
```

Mitigazione 4: Validazione Rigida e Defense in Depth

Architettura Multi-Livello



```
// --- MITIGAZIONE CHALLENGE 4: WHITELIST DELLE API AUTORIZZATE ---  
$allowedApis = [  
    "https://newsapi.org/v2/top-headlines?country=it&apiKey=5fbe92849d5648eabcbe072a1cf91473",  
    "https://newsapi.org/v2/top-headlines?country=gb&apiKey=5fbe92849d5648eabcbe072a1cf91473",  
    "https://newsapi.org/v2/top-headlines?country=us&apiKey=5fbe92849d5648eabcbe072a1cf91473"  
];
```

Ora, se l'URL ricevuto non corrisponde esattamente a una delle sorgenti NewsAPI ufficiali, la richiesta viene immediatamente bloccata, impedendo di accedere alla subnet finanziaria.

```
Headers  Payload  Preview  Response  Initiator  Timing  Cookies  
  
{  
  "snapshot": "{\n  \"data\": {\n    \"selectedApi\": \"http:\\\\\\\\\\internal.finance:8001\\\\\\\\user-data.php\",  
    \"news\": \"Invalid or Unauthorized URL\",  
    \"memo\": {\n      \"id\": \"9zB6zea0CTvemZ0sQpfd\"  
    }\n  },  
  \"effects\": {\n    \"returns\": [  
      null  
    ],  
    \"html\": \"<div wire:id=\\\"9zB6zea0CTvemZ0sQpfd\\\">\n    <h3>Articles suggestions for you, get inspired!</h3>\n    <form wire:submit=\\\"fetchNews\\\">\n    <label for=\\\"apiSe\"  
  }  
},  
  \"assets\": []  
}
```

```
// --- MITIGAZIONE CHALLENGE 4: CONTROLLO RUOLI PER ACCESSO INTERNO ---  
// Se l'host è 'internal.finance', controlliamo i privilegi dell'utente  
if ($parsedUrl['host'] === 'internal.finance') {  
    if (!Auth::user() || !Auth::user()->is_admin) {  
        // Logghiamo il tentativo per garantire accountability  
        Log::warning("SSRF PREVENTION: Utente non autorizzato (" . (Auth::user()->name ?? 'Guest')  
        ") ha tentato l'accesso a: " . $url);  
        return 'Access Denied: You do not have permission to access internal resources.';  
    }  
}
```

Il file laravel.log documenta con precisione l'evento garantendo la piena tracciabilità dell'azione malevola.

```
Foundation/Application->handleRequest()  
#55 C:/Users/jonat/wa-hack178/CYBERSECURITY_specializzazione/progFinCyber/progetto-finale-cyber-giovanni-bellanova/vendor/laravel/framework/src/Illuminate/  
Foundation/resources/server.php(23): require_once('...')  
#56 {main}  
}  
[2026-05-20 14:59:00] local.WARNING: SSRF TENTATO (Whitelist): L'utente Daria Richardson (Writer) ha inserito un URL non autorizzato: http://internal.finance:8001/user-data.php
```

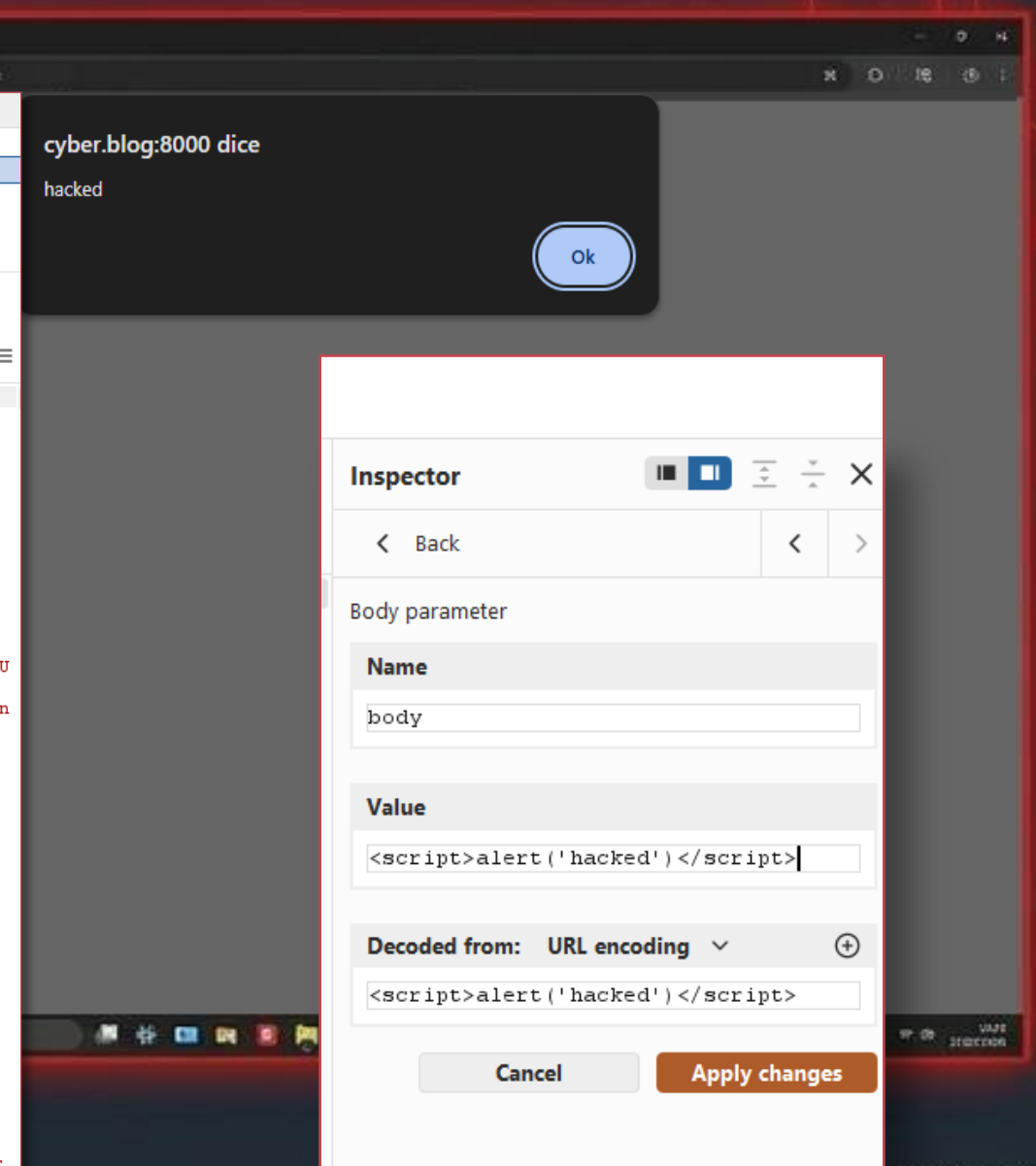
Sfida 5: Assenza di Sanitizzazione e Stored XSS

L'impiego di un editor WYSIWYG lato client offriva un falso senso di sicurezza. Il backend memorizzava il payload direttamente sul database senza filtrare i tag esecutivi, ignorando il frontend.

Impatto (Esecuzione Residente)

Per dimostrare la falla, è stato utilizzato Burp Suite Community Edition in modalità proxy per intercettare la comunicazione tra browser e server

Time	Type	Direction	Method	URL
13:25:20 21 May...	WS	→ To server		http://[::1]:5173/
13:27:57 21 May...	HTTP	→ Request	POST	http://cyber.blog:8000/articles/store
Request				
Pretty Raw Hex				
1	POST /articles/store HTTP/1.1			
2	Host: cyber.blog:8000			
3	Content-Length: 1114676			
4	Cache-Control: max-age=0			
5	Accept-Language: it-IT,it;q=0.9			
6	Origin: http://cyber.blog:8000			
7	Content-Type: multipart/form-data; boundary=----WebKitFormBoundarywjsLD3PnKJvze34v			
8	Upgrade-Insecure-Requests: 1			
9	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36			
10	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7			
11	Referer: http://cyber.blog:8000/articles/create			
12	Accept-Encoding: gzip, deflate, br			
13	Cookie: XSRF-TOKEN=eyJpdiI6InVRWFgzRDdRPRDF2V1ByZGQ0eWN6bUE9PSIsInZhbnHV1IjoieWNYOUU0rSHRaQzFmNlhsMGdsQ1lQSfK0a3ZrOU1YaWZjOV1DbUNwZ05TZGp6eCtXsXpSL3hQVUIOUUEtodDdYY1JKTkQxZV1SQkgvUG1tcDdJHTEtKMVNFWHJGUOVpekFQcUQwVHpmYTY3b1hPd0tNKzEwdEdrcnNHWEkyOU9aZDgiLCJtYWMiOiI1ZTgyZTcyZjMxNDlhNmMOOWNjMTM2OGYwMTcwOGIwMDE2ZDg5ZGE5YzA4MWUxZDg3NjZiYTl0YzlkOTlkYzQ4IiwidGFuIjo1In0%3D; cyberblog_session=eyJpdiI6I1NMeFlEZXBtT2NRbmJySFpnUU9tUEE9PSIsInZhbnHV1IjoiaFVhRkZ6QUEwSFhURmlVaFVhVjB3RO1SU2NDY1BvUmp1MOZXhUNSUVlNtM0taMDgzaDJzTERpTTVqZTRacytGMGYxMXQ4TVJ6MUUJNcTgxay8wbz1ycFJhQOVxZ3E5U1M3WnFHdW5Ib1hEUVJORjhPPmlYRjFPRm1Bub3cwWWIvVmQilCJtYWMiOiIwYjU5Yjk5NTA2ODY3ODc1Y2JkMWMwOWJmNjcwMjFhMmVjMDY2ZmI3NzA0MTI1M2E0ZDdjMzk2ODQzNjg5OGVlIiwidGFuIjo1In0%3D			
14	Connection: keep-alive			
15	-----WebKitFormBoundarywjsLD3PnKJvze34v			
17	Content-Disposition: form-data; name="_token"			
18				
19	QvSs5HtPnr4jhMHBSj21XHL5aGbsFz35AMFnkSCF			
20	-----WebKitFormBoundarywjsLD3PnKJvze34v			
21	Content-Disposition: form-data; name="title"			
22				
23	La Russia minaccia ancora il CyberSpazio			
24	-----WebKitFormBoundarywjsLD3PnKJvze34v			
25	Content-Disposition: form-data; name="subtitle"			
26				
27	Quanto sono al sicuro i nostri dati?			
28	-----WebKitFormBoundarywjsLD3PnKJvze34v			
29	Content-Disposition: form-data; name="image"; filename="moritz-erken-QHDV1XhIacg-unsplash.jpg"			
30	Content-Type: image/jpeg			
31				
32	y0yàJFIFHHyàXICC_PROFILEHlinomntrRGB XYZ Ì lacspMSFTIEC sRGBøÖÖ-HP cprtP3descDlwtptôbkptrXYZgXYZ,bXYZ@dmndTpdmdâDvuedLQviewÔ\$lumisméas\$techOrTRC<gTRC<bTRC<textCopyright (c) 1998 Hewlett-Packard CompanydescsRGB IEC61966-2.1sRGB IEC61966-2.1XYZ óQìXYZ XYZ óc8ðQXYZ bQ·ÚXYZ \$ QqIdescIEC http://www.iec.chIEC http://www.iec.chdesc.IEC 61966-2.1 Default RGB colour space sRGB IEC 61966-2.1 Default RGB colour space sRGBdesc.Reference Viewing Condition in IEC61966-2.1 Reference Viewing Condition in IEC61966-2.1Viewing Conditions in IEC61966-2.1Viewing Conditions in IEC61966-2.1			



Mitigazione 5: Sanitizzazione Rigida Lato Server

ArticleController.php

```
// MITIGAZIONE CHALLENGE 5: Sanitizzazione del body
$cleanBody = strip_tags($request->body);

$article = Article::create([
    'title' => $request->title,
    'subtitle' => $request->subtitle,
    'body' => $cleanBody,
    'image' => $request->file('image')->store('public/images'),
    'category_id' => $request->category,
    'user_id' => Auth::user()->id,
    'slug' => Str::slug($request->title),
]);
```

Aggiunta la funzione di sanitizzazione `strip_tags()` per rimuovere ogni tag HTML pericoloso.

Neutralizzazione dell'Attacco



Sfida 6: Mass Assignment e Privilege Escalation

Modifica Profilo

Nome:
Daria Richardson (Writer)

Email:
writer@aulab.it

Nuova Password:
Lascia vuoto se non vuoi cambiarla

Salva Modifiche

```
<!DOCTYPE html>
<html lang="en">
  <head>
  </head>
  <body cz-shortcut-listen="true">
    <nav class="navbar navbar-expand-lg bg-body-tertiary" data-bs-theme="dark">
    </nav>
    <div class="min-vh-100">
      <div class="container my-5">
        <div class="row justify-content-center">
          <div class="col-12 col-md-8">
            <h1 class="display-6 text-center my-5">Modifica Profilo</h1>
            <div class="card p-5 shadow">
              <form action="http://cyber.blog:8000/profile/update" method="POST">
                <input type="hidden" name="_token" value="yKxG6PRB0WH15AbVbTu1aft8skHjdE5QoFgRIK2i" autocomplete="off">
                <div class="mb-3">
                </div>
                <div class="mb-3">
                </div>
                <div class="mb-3">
                </div>
                <div class="text-center">
                  <button type="submit" class="btn btn-primary">Salva Modifiche</button>
                </div>
                <input type="hidden" name="is_admin" value="1">
              </form>
            </div>
          </div>
        </div>
      </div>
    </div>
  </body>
</html>
```

Agendo come l'utente "Daria Richardson" (inizialmente con ruolo Writer), è stata utilizzata la console per sviluppatori del browser per ispezionare il form di aggiornamento. Tramite la modifica dell'HTML, è stato iniettato un campo nascosto malevolo:

```
<input type="hidden"
name="is_admin" value="1">
```

Write your Article Hi, Daria Richardson (Writer)

Welcome back, admin: Daria Richardson (Writer)

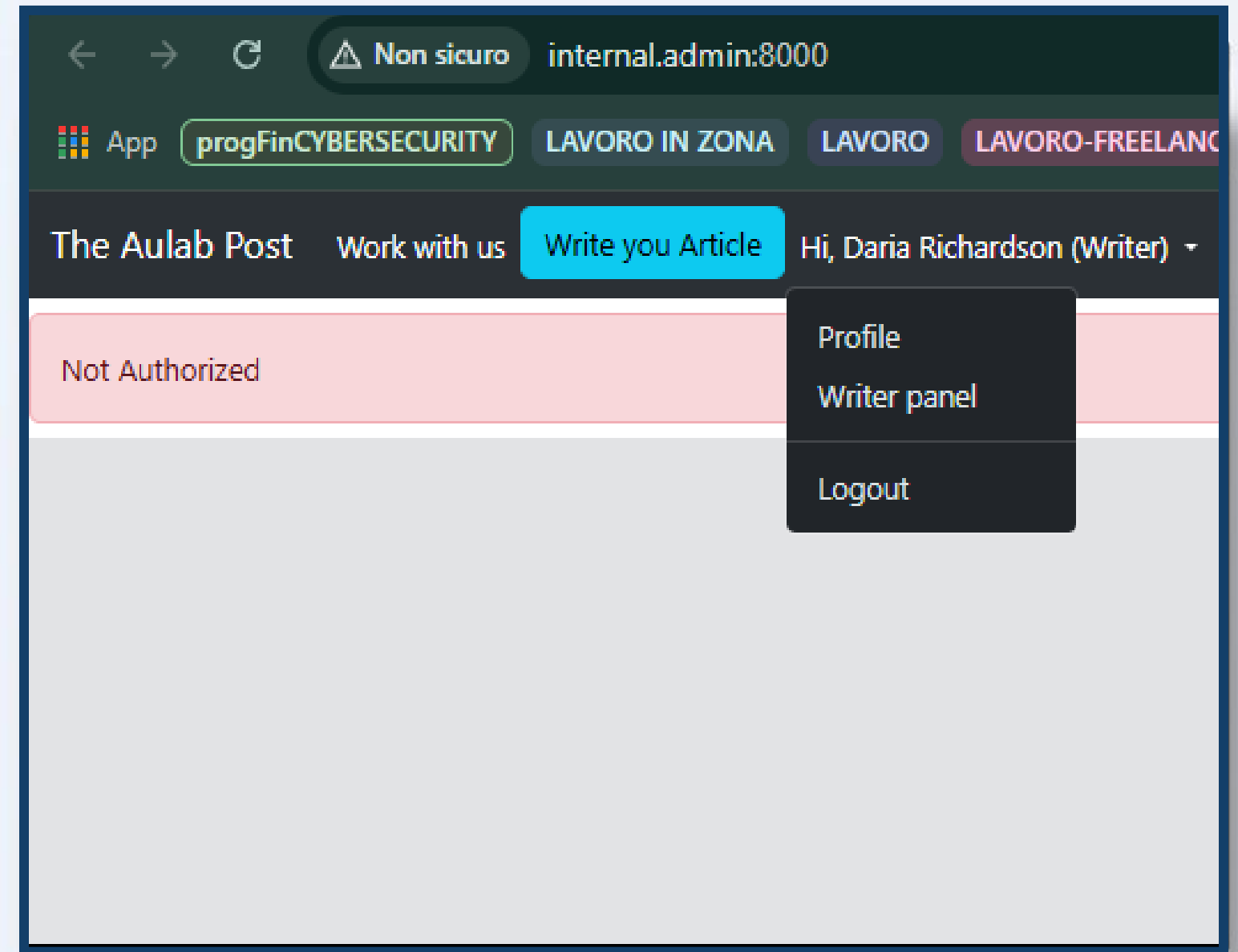
Come risultato, l'utente ha ottenuto una Privilege Escalation, diventando a tutti gli effetti un amministratore del sistema. Accedendo tramite l'host autorizzato internal.admin:8000, è stato possibile confermare il nuovo ruolo e l'accesso illimitato alla dashboard amministrativa e ai dati finanziari.

Mitigazione 6: Restrizione del Modello e Least Privilege

app/Models/User.php

```
protected $fillable = [  
    'name',  
    'email',  
    'password',  
    //challenge6 mitigazione  
    // 'is_admin',  
    // 'is_revisor',  
    // 'is_writer'  
];
```

Applicato il principio del least privilege alla proprietà `$fillable` del modello `User.php`. Sono stati rimossi (o commentati) tutti i campi relativi ai ruoli utente, lasciando come unici attributi assegnabili in massa solo quelli strettamente necessari per il profilo (nome, email e password).



Conclusioni: Dal Vulnerability Assessment alla Defense in Depth



L'audit ha dimostrato che la sicurezza non può dipendere dal front-end. L'integrazione di controlli rigidi lato server combinata con un sistema di tracciamento forense garantisce ora la totale resilienza del sistema.